

Catálogo de Controles de Seguridad del Proyecto (OWASP Top 10)

Sistema de Gestión de Pedidos - Leofit Solutions

1. Matriz de Mitigación de Riesgos OWASP Top 10 (2021-2026)

Código OWASP	Categoría de Vulnerabilidad	Control Implementado en Leofit	Componente / Archivo de Implementación
A01:2021	Broken Access Control (Pérdida de Control de Acceso)	Middleware de verificación de roles RBAC estricto (<code>requireRole('ADMIN')</code>) en rutas mutables de pedidos, stock y usuarios.	<code>backend/src/middlewares/role.middleware.ts</code>
A02:2021	Cryptographic Failures (Fallas Criptográficas)	Cifrado unidireccional de contraseñas con <code>bcrypt</code> (10 rondas de salt). Transmisión 100% cifrada bajo TLS 1.3 (HTTPS) y tokens JWT con firma HMAC-SHA256.	<code>backend/src/infrastructure/security/</code>
A03:2021	Injection (Inyecciones SQL / Command)	Uso estricto del Patrón Repositorio con consultas parametrizadas <code>\$1</code> , <code>\$2</code> , ... en <code>pg</code> (evita concatenación directa de strings) y validación de esquemas Zod.	<code>backend/src/infrastructure/repositories/pg.repositories.ts</code>
A04:2021	Insecure Design (Diseño Inseguro)	Validación atómica de inventario con bloqueos transaccionales <code>FOR UPDATE</code> para impedir condiciones de carrera (<i>race conditions / over-selling</i>).	<code>backend/src/infrastructure/repositories/pg.repositories.ts</code>

A05:2021	Security Misconfiguration (Configuración Errónea)	Cabeceras HTTP endurecidas vía helmet (HSTS, No-Sniff, Frameguard, X-XSS-Protection) y desactivación de divulgación de versiones (X-Powered-By).	<code>backend/src/app.ts</code>
A06:2021	Vulnerable and Outdated Components	Análisis automatizado de dependencias mediante npm audit y pipelines de CI/CD en GitHub Actions.	<code>.github/workflows/ci-cd.yml</code>
A07:2021	Identification and Auth Failures	Límite de intentos de autenticación (<i>Rate Limiting</i> de 20 intentos cada 15 min), expiración forzada de tokens JWT a las 24 horas.	<code>backend/src/middlewares/rateLimit.middleware.ts</code>
A08:2021	Software and Data Integrity Failures	Integridad de respaldos mediante firmas SHA-256 e inmutabilidad de logs de auditoría de estados.	<code>database/backup_strategy.sh</code>
A09:2021	Security Logging and Monitoring Failures	Registro estructurado de eventos HTTP mediante morgan y tabla de auditoría dedicada <code>order_status_history</code> con marcas temporales y usuarios responsables.	<code>database/schema.sql</code>
A10:2021	Server-Side Request Forgery (SSRF)	Restricción de URLs externas en el catálogo a dominios de confianza validados por esquemas Zod.	<code>backend/src/infrastructure/validators/schemas.ts</code>